

AI-Assisted DDoS Detection and Mitigation on AWS

Scenario-Based Proof-of-Concept Architecture Case Study

David-Aurel Djako

Cloud Architecture • Cybersecurity • Applied Machine Learning

ENVIRONMENT	Isolated AWS POC	ML APPROACH	SageMaker Random Cut Forest
COMPUTE	EC2 t3.medium	PERFORMANCE TARGET	1,000 requests/sec
TIMELINE	8 weeks	PROJECT ESTIMATE	\$74,500 / \$75,000 budget

Portfolio note: This project is a scenario-based systems design and implementation plan. It demonstrates architecture, security, ML, performance, compliance, and project-delivery decisions for a functional proof of concept; it is not presented as a production deployment for a real utility.

1. Project Challenge & Design Goals

The scenario centers on a regional power utility experiencing increased distributed denial-of-service (DDoS) activity against customer-facing and internal systems. The design goal was to create a small but functional AWS proof of concept that could detect abnormal traffic behavior, trigger controlled mitigation, preserve legitimate access, and produce evidence for a future enterprise decision.

DESIGN OBJECTIVES	ENGINEERING CONSTRAINTS
• Detect DDoS-like anomalies within 20 seconds • Sustain a defined 1,000 requests/second test workload • Preserve legitimate synthetic user access • Automate a controlled response through AWS WAF • Keep all testing isolated from production and OT systems	• 8-week delivery window • Two-person primary project team • \$75,000 pilot budget • Synthetic legitimate and attack traffic only • AWS-native security, observability, data, and ML services

Why this design matters

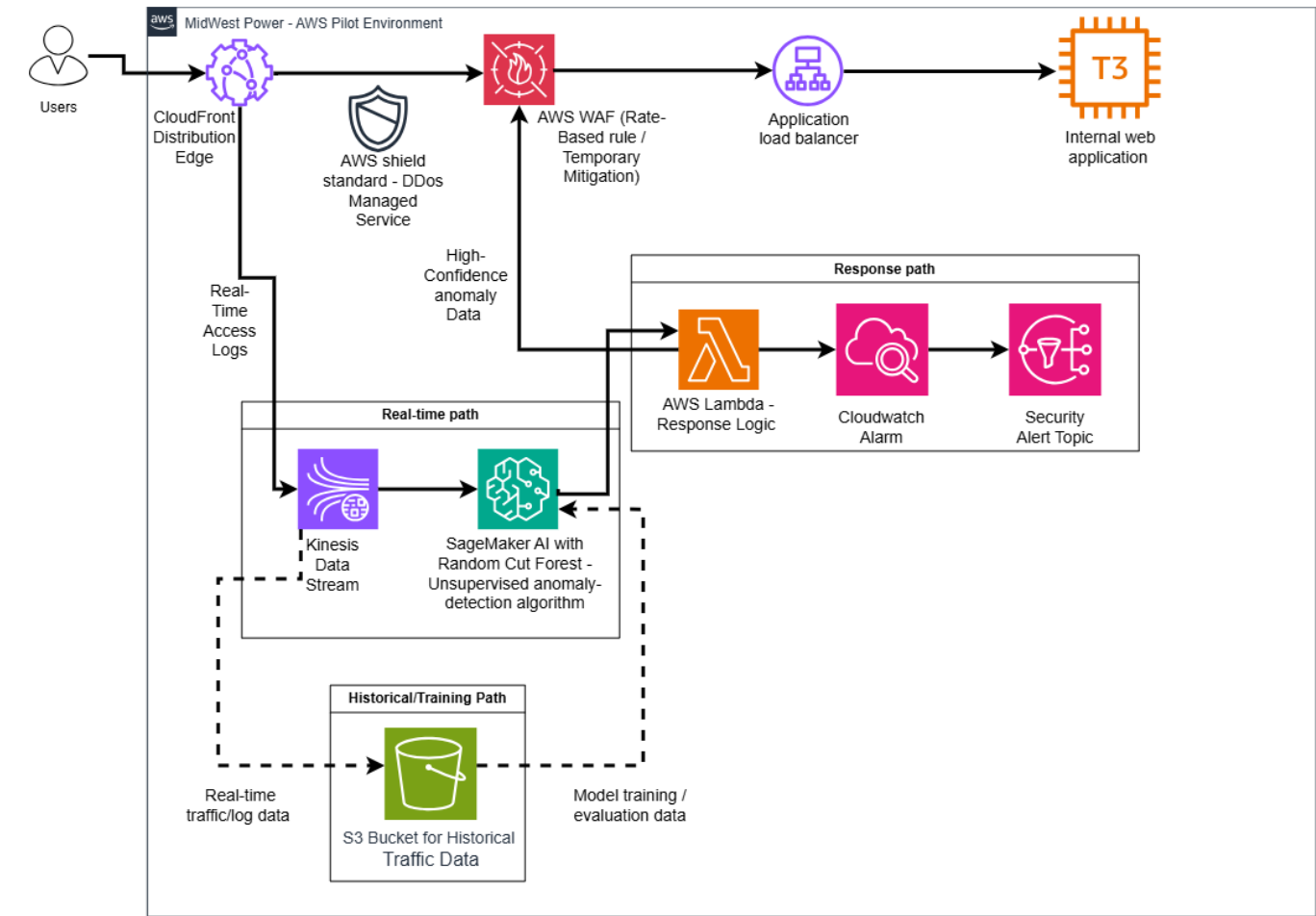
The architecture deliberately separates application delivery, anomaly detection, mitigation, historical data, and observability. That separation makes it easier to test each control independently, limit blast radius, and evaluate whether a machine-learning signal adds operational value without allowing the model to make unrestricted production decisions.

Key design principle

A high anomaly score is treated as a security signal, not proof of malicious intent. The response path therefore uses a validated threshold and controlled WAF actions, while a separate ethical test checks whether unusual but legitimate traffic is unnecessarily blocked.

2. AWS Architecture

The solution routes synthetic users through edge protection and application-layer controls, mirrors traffic telemetry into a real-time anomaly-detection path, and uses an isolated response workflow for mitigation and notification.



Architecture designed for the POC. The application tier terminates at an EC2 t3.medium instance behind an Application Load Balancer.

Application path	CloudFront → AWS WAF / Shield Standard → Application Load Balancer → EC2 t3.medium test web application
Detection path	CloudFront real-time access logs → Kinesis Data Streams → processed numerical observations → SageMaker Random Cut Forest anomaly scoring
Response path	Qualifying anomaly event → AWS Lambda response logic → controlled AWS WAF updates
Observability	CloudWatch metrics/logs/alarms → Amazon SNS security notifications
Historical path	Amazon S3 stores reviewed baseline data, anomaly results, and evaluation data; S3 Versioning supports recovery

3. Detection, Response & Data Design

Unsupervised anomaly detection

The ML design uses Amazon SageMaker AI Random Cut Forest (RCF) to learn the structure of baseline traffic and assign anomaly scores to new observations. The real-time stream is processed into numerical observations before scoring. Traffic that exceeds a validated threshold is treated as potentially malicious and passed to the response workflow.

INPUT SIGNALS	MODEL DECISION	CONTROLLED RESPONSE
Request volume, timing, response behavior, and other aggregated traffic characteristics	RCF produces an anomaly score relative to learned baseline patterns	Lambda evaluates qualifying events and updates configured WAF controls; CloudWatch/SNS records and alerts

Training-data integrity

The design avoids uncontrolled continuous retraining. Historical data is reviewed and separated so suspected malicious traffic does not silently become part of the “normal” baseline. Periodic retraining and evaluation use validated historical data instead.

Application compute baseline

The representative customer portal is hosted on an EC2 t3.medium instance (2 vCPUs, 4 GiB memory, up to 5 Gbps network performance). This is treated as a starting compute baseline that must prove itself under test rather than as a guaranteed production sizing decision.

Data protection and recovery

- Least-privilege IAM roles and policies restrict resource access.
- S3 data is encrypted at rest and supported service paths use encryption in transit.
- A 30-day post-project retention policy is verified through S3 lifecycle configuration.
- S3 Versioning is used to demonstrate recovery from accidental object modification or deletion.
- No production customer data, OT data, or live utility infrastructure enters the POC.

4. Validation Strategy

The test plan translates the design into measurable acceptance criteria across performance, functionality, compliance, ethics, and privacy. The POC is successful only if the architecture performs as a system—not merely if the ML model produces an anomaly score.

TEST AREA	WHAT IS MEASURED	ACCEPTANCE / EVIDENCE	WHY IT MATTERS
Detection latency	Time from simulated attack start to threshold-crossing anomaly score	≤ 20 seconds	Validates response speed
Throughput	End-to-end processing at peak synthetic load	1,000 requests/sec for 5 minutes while preserving latency target	Tests sustained pilot load
EC2 compute	CPU, memory, network, CPU credits	Avg CPU <70%; memory <80%; network stays within t3.medium supported capacity	Tests instance sizing
Mitigation	Lambda → WAF control path	Mitigation occurs and legitimate traffic remains available	Validates automated response
Encryption	S3 at rest + service communications	SSE-S3 enabled; encrypted supported paths	Validates data protection
Access control	Authorized vs unauthorized identities	Authorized actions allowed; unauthorized attempts denied	Validates least privilege
Retention	S3 lifecycle expiration	30-day post-project retention configured	Limits unnecessary data persistence
Backup/recovery	Restore a prior S3 object version	Previous valid object recovered successfully	Validates recovery procedure
Ethical / privacy	False-positive handling and production-data exclusion	Legitimate synthetic access preserved; no production customer data processed	Reduces user harm and privacy risk

Performance engineering takeaway: The t3.medium is intentionally treated as a testable assumption. If resource thresholds are exceeded for a sustained period, the correct outcome is to recommend a larger instance rather than force the workload to fit the original sizing choice.

5. Delivery Plan, Budget & Ownership

PERIOD	PRIMARY FOCUS	MILESTONE
Sep 9–11	Requirements, architecture, security/isolation, schedule	Design approved
Sep 14–18	AWS environment, IAM, EC2 app, ALB, CloudFront, WAF	POC environment operational
Sep 21–25	CloudFront logging, Kinesis, processing pipeline, S3	Traffic pipeline operational
Sep 28–Oct 2	RCF training, threshold validation, real-time scoring	AI detection validated
Oct 5–9	Lambda response, WAF integration, CloudWatch/Agent, SNS	Detection/mitigation/notification operational
Oct 12–16	Performance, functionality, compliance, ethical, legal tests	Initial testing completed
Oct 19–23	Defect correction, retesting, final acceptance review	Acceptance criteria verified
Oct 26–30	Configuration/ML documentation, final report, recommendations	Project closeout

Team ownership

Cloud Architect / Project Lead	Machine Learning Engineer
AWS environment, network/security controls, architecture integration, cost/schedule coordination, final validation.	Traffic-processing pipeline, SageMaker RCF training, threshold validation, model evaluation, ML-related risk management.

Cost position

\$74,500 estimated project cost against a \$75,000 pilot budget — a \$500 favorable variance (~0.67% below budget).

The estimate is intentionally personnel-heavy because the project depends more on specialized cloud and ML expertise than on physical infrastructure. AWS cloud spend is usage-dependent and is monitored against a planned baseline.

6. Risks, Trade-offs & Future Improvements

RISK / TRADE-OFF	DESIGN RESPONSE
Legitimate traffic resembles an attack	Use a validated anomaly threshold, measure false positives, and preserve legitimate access during the ethical test.
Detection latency exceeds 20 seconds	Profile the real-time pipeline and tune processing/model configuration before retesting.
EC2 resource saturation	Measure CPU, memory, networking, and CPU credits; resize if sustained thresholds are exceeded.
Training-data contamination	Allow only reviewed historical traffic into periodic retraining.
IAM or AWS misconfiguration	Reapply least-privilege controls and retest access before acceptance.
Cloud spend exceeds plan	Use AWS Budgets and resize/stop/remove unnecessary resources.
Schedule pressure	Prioritize core POC functionality and reserve the validation week for remediation/retesting.

What I would evaluate next

- Compare RCF results with alternative anomaly-detection approaches and rule-based baselines.
- Introduce infrastructure-as-code for repeatable deployment and controlled environment recreation.
- Add richer dashboards for model score distribution, WAF actions, application health, and false-positive trends.
- Run longer-duration load tests and compare the t3.medium with non-burstable or autoscaled application tiers.
- Expand the response design with human approval gates for higher-impact mitigation actions.
- Test multi-region resilience and recovery assumptions if the design advances beyond the pilot stage.

7. What This Project Demonstrates

AWS Solution Architecture	CloudFront, WAF, Shield Standard, ALB, EC2, Kinesis, SageMaker, Lambda, CloudWatch, SNS, S3, IAM
Cloud Security Engineering	DDoS protection, application-layer filtering, least privilege, encryption, controlled mitigation, privacy isolation
Applied Machine Learning	Unsupervised anomaly detection, baseline design, threshold validation, training-data integrity, model evaluation
Performance Engineering	Latency, throughput, CPU, memory, networking, burst-credit monitoring, acceptance thresholds
Observability & Incident Response	Metrics, logs, alarms, notification paths, response evidence, defect/retest loop
Technical Project Planning	Requirements traceability, WBS, task-level schedule, budget, quality plan, risk management, acceptance criteria

Recruiter conversation starters

- Why I chose a burstable t3.medium as a test baseline instead of treating it as a production sizing answer.
- How I would prevent anomaly scores from becoming an unsafe “automatic truth” in the mitigation workflow.
- How the performance, compliance, and ethical tests map back to explicit technical requirements.
- How I would evolve this scenario-based POC into a production-ready, infrastructure-as-code deployment.

Selected technical references

- AWS documentation: Random Cut Forest (RCF) algorithm and how RCF works
- AWS documentation: CloudFront real-time access logs and Kinesis Data Streams
- AWS documentation: AWS WAF rate-based rules and Shield Standard
- AWS documentation: EC2 general-purpose instance specifications and CloudWatch instance metrics
- AWS documentation: CloudWatch Agent metrics, S3 Lifecycle expiration, and S3 Versioning
- AWS Pricing Calculator and AWS Budgets documentation

Source basis: Adapted from the final submitted system design paper. The portfolio version removes academic/rubric framing and emphasizes the technical decisions, test strategy, delivery plan, and skills demonstrated.